

Détection d'intrusion

Stéphane Gill

Stephane.Gill@CollegeAhuntsic.qc.ca

Table des matières

Introduction.....	2
Détection d'Intrusion basée sur l'hôte.....	2
Détection d'Intrusion réseau.....	3
Tripwire.....	3
SWATCH.....	4
Démarrage de SWATCH.....	4
Format du fichier de comparaison.....	4
Exemple de fichier de comparaison.....	5
SNORT.....	6
Installation de Snort.....	6
Utilisation de Snort.....	7
Rapport Snort.....	9
portSentry.....	9
Paramétrage.....	9
Démarrage.....	10
Références.....	10

Document écrit par Stéphane Gill

© Copyright 2013 Stéphane Gill

Ce document est soumis à la licence GNU FDL. Permission vous est donnée de distribuer et/ou modifier des copies de ce document tant que cette note apparaît clairement.

Introduction

Les systèmes de détection d'intrusion permettent de détecter en temps réel les tentatives d'intrusion, de neutraliser ces attaques et d'assurer ainsi la sécurité d'un réseau ou d'un ordinateur.

Deux méthodes sont principalement utilisées par les SDI :

- la reconnaissance de signatures et
- la détection d'anomalies.

La reconnaissance de signatures est une approche qui consiste à rechercher l'élément surveillé dans une banque de signatures d'attaques connues. Le SDI fait donc appel à une bibliothèque de signatures et ne peut alors détecter que les attaques dont il possède la signature.

De son côté, la détection d'anomalies utilise l'analyse de statistiques du système : changement de mémoire, utilisation excessive du CPU, etc. Le SDI signalera les divergences par rapport au fonctionnement normal de l'ordinateur ou du réseau.

Il existe deux types de SDI :

- les SDI basés sur l'hôte.
- les SDI réseau.

Ces deux types sont décrits dans les sections suivantes.

Détection d'Intrusion basée sur l'hôte

Les systèmes de détection d'intrusion basés sur l'hôte analysent exclusivement l'information concernant un ordinateur. Comme ils n'ont pas à analyser le trafic du réseau mais seulement les activités d'un ordinateur ils se montrent habituellement plus précis à détecter les attaques. Ces SDI utilisent deux sources d'information pour identifier les attaques : les journaux et les traces d'audit du système d'exploitation. Les traces d'audit sont précises et détaillées, elles fournissent une meilleure information alors que les journaux. Les journaux ne fournissent que l'information essentielle, ils sont donc plus petits. En raison de leur petite taille l'analyse des journaux est mieux contrôlée et plus précise.

Voici quelques exemples de SDI basés sur l'hôte :

- Tripwire (<http://www.tripwire.com/products/index.html>)
- SWATCH (http://freshmeat.net/redir/swatch/10125/url_homepage/swatch)
- DragonSquire (<http://www.enterasys.com/ids/squire/>)
- Tiger (http://freshmeat.net/redir/tiger-audit/30581/url_homepage/tiger)
- Security Manager (<http://www.netiq.com/products/sm/default.asp>)

Détection d'Intrusion réseau

Le rôle essentiel d'un SDI réseau est l'analyse et l'interprétation des paquets circulant sur ce réseau. Un SDI réseau est donc un simple renifleur de paquets qui recherche des paquets suspects. L'identification de ces paquets suspects se fait en comparant les paquets interceptés à une banque de signatures des attaques courantes.

Voici quelques exemples de SDI réseau :

- NetRanger (<http://www.cisco.com>)
- Dragon (<http://www.securitywizards.com>)
- NFR (<http://www.nfr.net>)
- Snort (<http://www.snort.org>)
- DTK (<http://all.net/dtk/dtk.html>)
- ISS RealSecure (<http://www.uh.edu/infotech/software/unix/realsecure/index.html>)

Tripwire

Tripwire est un outil de détection des intrusions qui vérifie l'intégrité d'un système de fichiers et informe de toutes modifications apportées à des fichiers importants. Pour ce faire, le logiciel crée une base de données contenant la signature numérique des fichiers que l'administrateur souhaite surveiller. Lors de la phase de contrôle d'intégrité, Tripwire recalcule la signature numérique de chacun des fichiers à surveiller et vérifie que cette signature correspond bien à celle calculée lors de la création de la base de données. Si les deux signatures ne correspondent pas, Tripwire émet alors une alerte.

Les fichiers à surveiller peuvent être classés selon différents degrés de criticité. Tripwire peut être assez complexe à configurer car son objectif de sécurité entraîne un chiffrement des fichiers utilisés par l'outil lui-même. Les fichiers de configuration de Tripwire sont chiffrés, la base de données peut (doit) aussi être chiffrée afin d'éviter que ce soit la base qui soit altérée en dehors

du contrôle de l'administrateur. En conséquence, chaque nouveau réglage entraîne un re-chiffrement des fichiers de configuration et de la base de données.

Les éventuelles alertes suite à des modifications de fichiers peuvent être transmises par courriel, ce qui évite que ce soit le rapport du contrôle qui soit intercepté.

Il existe une branche OpenSource du logiciel sous la Licence publique générale GNU qui est la continuité du logiciel original. Les développeurs du logiciel ont ensuite étendu les fonctionnalités du logiciel en branche commerciale, via la compagnie qu'ils ont fondée.

SWATCH

Swatch est un outil de détection d'intrusion simple écrit en Perl. Il surveille les fichiers de journaux à la recherche d'entrées particulières. Lorsqu'une entrée particulière est identifiée SWATCH entreprend l'action qui lui a été spécifiée. Les actions suivantes peuvent être spécifiées : envoyer un courriel, envoyer un fax, envoyer un message par télé-avertisseur...

Démarrage de SWATCH

La commande suivante démarre SWATCH :

```
swatch -c mathfile --tail logfile
```

- `logfile` est le chemin d'accès d'un fichier journal du système.
- `matchfile` est un fichier décrivant les chaînes de caractères à rechercher dans le fichier de journal ainsi que les actions à entreprendre chaque fois que la chaîne est trouvée.

Format du fichier de comparaison

Le fichier de comparaison de SWATCH est un fichier texte débutant par le mot clé `watchfor` suivi d'une expression régulière. L'expression régulière indique à SWATCH le modèle qu'il doit rechercher dans le journal. Voici un exemple qui fera en sorte que SWATCH recherchera dans le journal la chaîne « ROOT LOGIN » ou « uid = 0 » :

```
watchfor /ROOT LOGIN|uid=0/
```

La ligne `watchfor` est toujours suivie d'une série de lignes décrivant les actions à prendre lorsqu'une correspondance est trouvée. Voici un exemple d'action :

Détection d'intrusion

```
echo red  
mail adresses=root@MonReseau.net, sujet="Vilain pirate, vas-t'en"  
bell 3
```

Action	Description
echo [mode]	Affiche au terminal l'entrée du journal qui a été identifié. Le mode peut-être : <i>bold</i> , <i>underscore</i> , <i>blink</i> , <i>inverse</i> , <i>black</i> , <i>red</i> , <i>green</i> , <i>yellow</i> , <i>blue</i> , <i>cyan</i> ou <i>white</i> .
bell [count]	Déclenche un signal sonore. L'option <i>count</i> spécifie le nombre de signaux sonores.
exec command [args]	Exécute la commande spécifiée, avec les arguments fournis. L'argument \$N est champs N de l'entrée dans le journal. Les champs sont séparés par des espaces.
mail [addr],[subj]	Envoie par courrier électronique l'entrée de journal à l'adresse (<i>addr</i>) spécifiée. <i>subj</i> est le sujet du message envoyé.
pipe command	Envoie l'entrée de journal vers l'entrée standard d'une commande.
write [user]	Affiche l'entrée de journal au terminal d'un usager.
continue	Demande à SWATCH de trouver une correspondance de cette entrée de journal avec un autre watchfor du fichier de comparaison.

Exemple de fichier de comparaison

Voici un fichier de comparaison type :

```
watchfor /ROOT LOGIN|uid=0/
echo red
mail adresses=root@MonReseau.net,objet="SWATCH: Root activity"
bell 2

watchfor /FAILED LOGIN 3 .* FOR root/
echo red
mail adresses=root@MonReseau.net,objet=" SWATCH: Root login failed"
bell 2
```

```
watchfor /REPEATED|repeated/  
echo red  
mail adresses=root@MonReseau.net, sujet=" SWATCH: Repeated activity"  
bell 2  
  
watchfor /useradd/  
echo red  
mail adresses=root@MonReseau.net, sujet=" SWATCH: useradd"  
bell 2  
  
watchfor /file system full/  
echo red  
mail adresses=root@MonReseau.net, sujet=" SWATCH: file system full"  
bell 2
```

SNORT

Snort est le système de détection des intrusions le plus répandu avec plus de 100 000 installations recensées dans le monde. Snort est un logiciel « Open Source » qui dispose de fonctionnalités similaires à celles proposées par des systèmes de détection commerciaux.

Snort sert à surveiller tout le trafic sur un réseau d'une manière active et en temps réel à la recherche de paquets suspects. Snort est donc un simple renifleur de paquets conçu à des fins de détection d'intrusion.

Installation de Snort

Les processus d'installation de Snort implique plusieurs composants :

- libpcap
- libnet
- Snort

Les bibliothèques libpcap et libnet doivent être installées pour permettre l'utilisation de Snort.

Utilisation de Snort

Avant de pouvoir utiliser Snort il faut définir un ensemble de règles contenant les modèles (*patterns*) qui correspondent aux attaques courantes. Un grand nombre de règles ont été compilées par la communauté Snort. Plusieurs ensembles de règles sont disponibles pour téléchargement sur le site www.snort.org. Le tableau suivant donne des détails sur certains de ces ensembles de règles.

Ensemble de règles	Pertinence
Backdoor	Utile pour les réseaux Windows et mixtes.
DDos	Recommandé pour toutes les installations.
Explois	Essentiel à toutes les installations.
Finger	Recommandé pour toutes les installations.
FTP	Essentiel si un service FTP est disponible sur le réseau.
ICMP	Recommandé pour toutes les installations.
MISC	Recommandé pour toutes les installations.
NetBios	Essentiel si le service NetBios est utilisé sur le réseau et pour les réseaux Windows et mixtes.
RPC	Recommandé pour toutes les installations.
Rservices	Recommandé pour toutes les installations.
Scans	Recommandé pour toutes les installations.
SMTP	Essentiel si un service SMTP est disponible sur le réseau.
Telnet	Essentiel si un service telnet est disponible sur le réseau.
Virus	Recommandé pour les réseaux Windows et mixtes.
Web-cgi	Essentiel si un service Web est disponible sur le réseau
Web-ColdFusion	Essentiel si un service Cold Fusion est disponible sur le réseau.
Web-FrontPage	Essentiel pour les réseaux Windows ou si un service FrontPage est disponible.

Ensemble de règles	Pertinence
Web-IIS	Essentiel pour les réseaux Windows ou si un serveur IIS est disponible.

Pour assembler votre ensemble final de règles, il faut éditer le fichier `/etc/snort.rules`.

Voici un exemple de fichier `/etc/snort.rules` :

```

include /etc/snort/classification.config

include /etc/snort/exploit.rules
include /etc/snort/scan.rules
include /etc/snort/finger.rules
include /etc/snort/ftp.rules
include /etc/snort/telnet.rules
include /etc/snort/smtp.rules
include /etc/snort/rpc.rules
include /etc/snort/rservices.rules
include /etc/snort/backdoor.rules
include /etc/snort/dos.rules
include /etc/snort/ddos.rules
include /etc/snort/dns.rules
include /etc/snort/netbios.rules
include /etc/snort/web-cgi.rules
include /etc/snort/web-coldfusion.rules
include /etc/snort/web-frontpage.rules
include /etc/snort/web-iis.rules
include /etc/snort/web-misc.rules
include /etc/snort/sql.rules
include /etc/snort/x11.rules
include /etc/snort/icmp.rules
include /etc/snort/shellcode.rules
include /etc/snort/misc.rules
include /etc/snort/policy.rules
include /etc/snort/info.rules
# include /etc/snort/icmp-info.rules
include /etc/snort/virus.rules
include /etc/snort/local.rules

```

Le démarrage de Snort avec un ensemble de règles se fait par la commande suivante :

```
snort -D -A alert -c /etc/snort.rules
```

Rapport Snort

Silicon Defence a créé un outil qui permet de créer des rapports à partir des fichiers journaux de Snort. Ce programme s'appelle Snortsnarf et est disponible sur le site www.silicondefence.com. Snortsnarf est conçu pour tourner en tant que tâche CRON. Nombre d'options sont disponibles, mais la syntaxe la plus simple est :

```
snortsnarf.pl -d outputdirectory snortfile
```

outputdirectory est le répertoire où sera généré le rapport en format HTML. *snortfile* est le fichier de journal de Snort qui s'appelle habituellement */var/log/snort.alert*.

Un autre outil de génération de rapports est disponible. Cet outil s'appelle ACID et il est disponible à l'adresse suivante : www.andrew.cmu.edu/~rdanyliw/snort/snortacid.html. Pour fonctionner correctement cet outil nécessite l'installation de MySQL, php et Apache.

portSentry

PortSentry est un outil qui permet de détecter le balayage de ports et de prendre une action pour bloquer l'accès à l'ordinateur qui a effectué le balayage. Les actions prises pour bloquer l'accès à l'ordinateur attaquant peuvent être paramétrées pour être faites via TCPWrapper et/ou iptables.

Paramétrage

PortSentry est disponible sur le site : www.psionic.org et il peut s'installer à partir d'un paquetage RPM disponible sur le site : rpmfind.net. Une fois l'installation terminée le paramétrage se fait à partir des 4 fichiers qui se trouvent dans le répertoire : */etc/portsentry* :

- *portsentry.conf*, fichier principal de configuration.
- *portsentry.ignore*, listes des machines et adresses qu'il faut ignorer.
- *portsentry.history*, listes des adresses bloquées
- *portsentry.modes*, mode de lancement de *portsentry*

C'est en modifiant le fichier *portsentry.conf* que l'on choisit les actions prises, voici en exemple une partie de ce fichier de paramétrage :

```
#####  
# iptables      #  
#####  
KILL_ROUTE="/sbin/iptables -I INPUT -s $TARGET$ -j DROP"  
  
#####  
# TCP Wrappers#  
#####  
#KILL_HOSTS_DENY="ALL: $TARGET$"  
#KILL_HOSTS_DENY="ALL: $TARGET$ : DENY"
```

Démarrage

L'installation utilisant les paquetages RPM fournit habituellement un script de démarrage et d'arrêt de portsentry. Ce script s'utilise de la façon suivante :

```
[root@poil root]# /etc/rc.d/init.d/portsentry start  
Starting portsentry -atcp: [ OK ]  
Starting portsentry -audp: [ OK ]
```

Références

Stefen Norberg, « Securing Windows NT/2000 Servers for the Internet », O'Reilly, 2001.

Eric Maiwald, « Sécurité des réseaux », Campus press, 2001.

Aron Hsiao, « Sécurité sous Linux », Campus press, 2001.

« Red Hat Linux 9 : Red Hat Linux Security Guide », Red Hat Inc., 2002.

« Red Hat Linux 9 : Guide de référence Red Hat ». Red Hat Inc., 2003.